



Securing AI in production with Microsoft Defender for Cloud



Jorge Castañeda
Microsoft MVP Security

La IA llegó a producción más rápido que la seguridad que la cubre.

La superficie nueva no es el modelo. Son las dependencias alrededor.

Endpoint de inferencia

Expuesto a internet, identidad sobre-permisionada

Datos de grounding

Alcanzables por lateral movement, data poisoning

El agente actúa solo

Encadena herramientas y acciones sin gobierno

Pregunta de board: no es "¿usamos IA?", es "¿quién responde cuando el agente filtra datos?"

■ Cuatro capas, no una

Asegurar IA en producción es asegurar una cadena de suministro completa, del código a la nube al agente. Cada capa tiene un riesgo dominante.



Microsoft Defender for Cloud unifica las cuatro como un CNAPP, con AI-SPM y AI Threat Protection.

■ Defender for Cloud: el CNAPP que asegura la IA

Una plataforma, dos motores que cubren todo el ciclo de vida de la IA generativa.

AI-SPM

AI Security Posture Management

- Descubre el AI Bill of Materials (modelos, SDKs, servicios) agentless y multicloud
- Recomendaciones de configuración y de IaC priorizadas por riesgo
- Attack path analysis sobre las cargas de IA

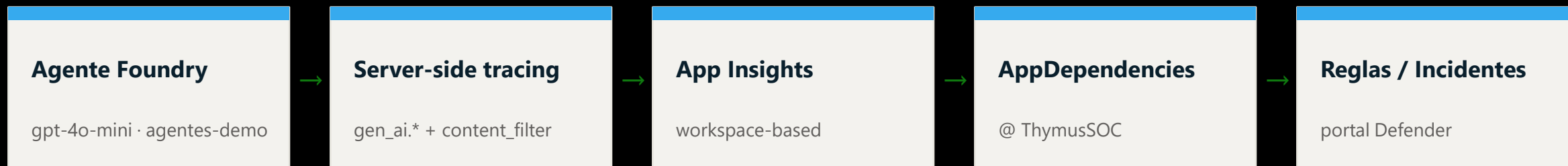
AI Threat Protection

Detección en runtime

- Alertas sobre prompts sospechosos y comportamiento anómalo del endpoint
- Potenciado por Azure AI Content Safety Prompt Shields y Threat Intelligence
- Correlación e investigación en el portal Defender unificado (XDR)

■ EL CASO REAL: NO ES UN DIAGRAMA, ESTÁ CORRIENDO

Una plataforma conversacional multi-agente en mi tenant



30

analytic rules

18

hunting queries

2

watchlists

v2.0

AI Red Team taxonomy

Base de detección desplegada sobre la telemetría del agente (bundle Monitoring AI Agents · D. Alonso), alineada a MITRE ATT&CK y a la taxonomía Microsoft AI Red Team v2.0.

DEMO

Detección por capa

Mismo patrón en cada capa:

1 Identificar el riesgo

2 Detectar la amenaza

3 Aplicar la best practice

01

Infraestructura

AI-SPM descubre el AI BOM del workload Foundry, agentless y multicloud.

IDENTIFICAR

- Inventario de modelos, SDKs y servicios desplegados
- AI Bill of Materials del recurso Foundry creado

DETECTAR

- Misconfiguraciones de IaC
- Vulnerabilidades en contenedores y dependencias (TensorFlow, PyTorch, LangChain)

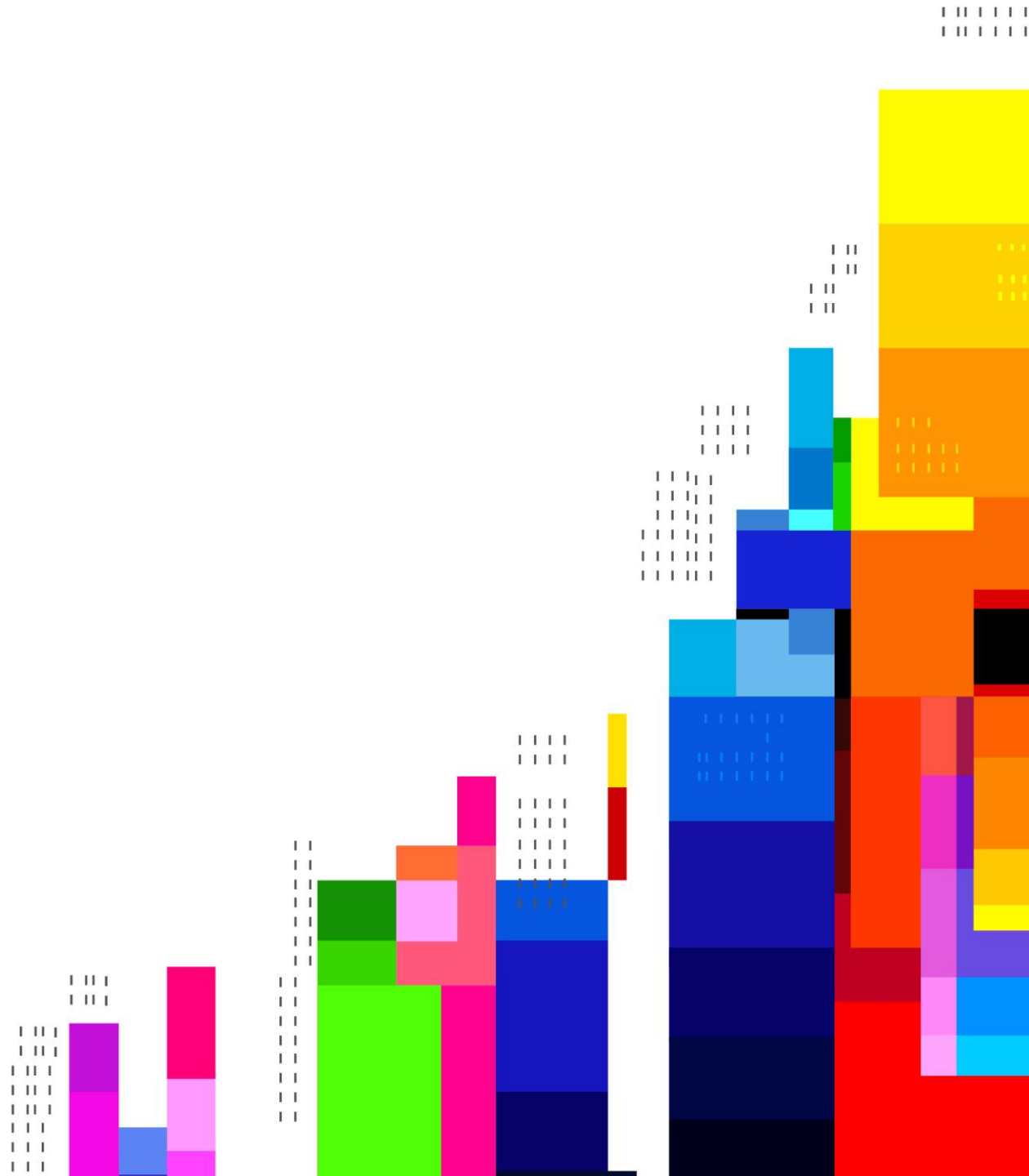
BEST PRACTICE

- Private endpoints
- Managed identity e identity-based auth
- Restringir endpoints públicos

Para decisores: No puedes proteger lo que no sabes que existe. El AI BOM es el inventario que el board pide.

LIVE DEMO

[Cloud Security Explorer]



02

Datos

Attack path analysis revela la combinación tóxica antes de que ocurra el incidente.

IDENTIFICAR

- Data Security Posture Management descubre datastores con datos sensibles ligados a la IA

DETECTAR

- Grounding alcanzable desde internet vía lateral movement
- Susceptible a data poisoning

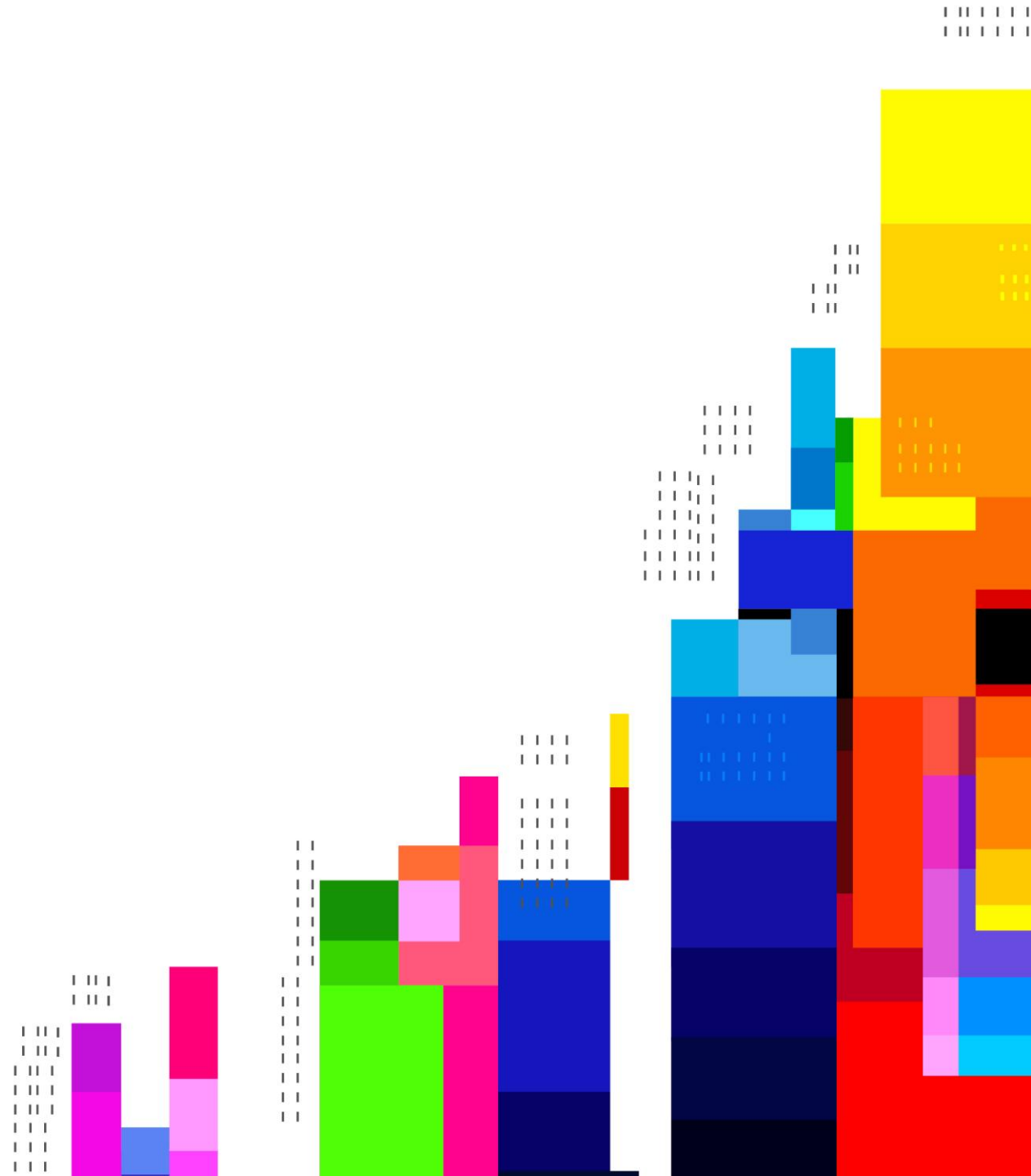
BEST PRACTICE

- Aislar y autenticar el datastore
- Least privilege
- Cortar el camino de exposición

Para decisores: Aquí se filtra la información confidencial. El attack path es la narrativa del incidente, dibujada antes de que pase.

LIVE DEMO

[Attack Path Analysis]



03 Servicios de IA + Agentes

Threat protection en runtime, más detección agéntica profunda sobre la telemetría gen_ai.

Servicios de IA

- Prompt Shields detectan jailbreak y prompt injection
- Content Safety: verdicts de severidad
- Threat Intelligence + monitoreo contextual

Agentes

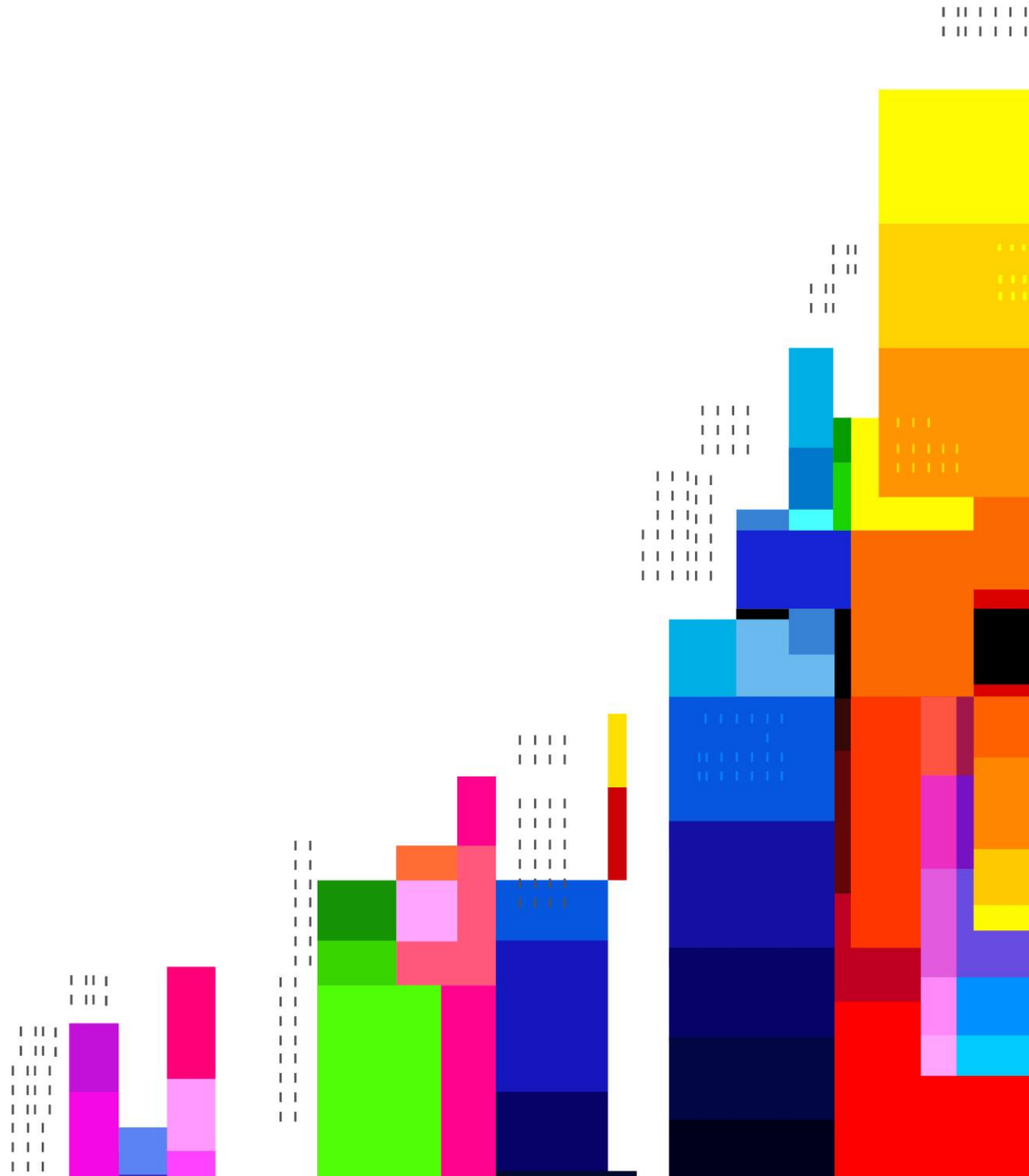
- Identidad del agente y permisos least-privilege
- Tool chaining, memory poisoning, HitL bypass
- Cross-agent invocation (lateral movement)

EN VIVO

Disparo el harness adversarial contra el agente → en 2-5 min los spans llegan a AppDependencies → las reglas correlacionan en incidentes → de cada uno nuestro agente, conversación, prompt y verdict del filtro. El mismo cuadro que el SOC usaría en producción.

LIVE DEMO

[Harness Adversarial]



Casos de uso: lo que se enciende en vivo

Cada prompt adversarial del harness mapea a una detección concreta del bundle.

Caso de uso (ataque)	Capa	Detección que dispara
Jailbreak / bypass de guardrails	Servicios IA	FoundryGuardrailJailbreakDetected
Prompt injection / coerción de tool	Servicios IA	FoundryPromptInjectionPatterns
Fuga del system prompt	Servicios IA	FoundrySystemPromptDisclosure
Secretos en el prompt	Datos	FoundrySecretsInPrompt
Exfiltración masiva ("dump all", select *)	Datos	FoundryBulkDataExfiltrationIntent
Suplantación de autoridad (admin/CFO)	Agentes	FoundryPrivilegeEscalationClaim
Fingerprinting del modelo	Servicios IA	AgentModelFingerprinting (hunt)
URL maliciosa en el contenido	Datos	FoundrySuspiciousUrlInContent
ASCII smuggling (unicode invisible)	Agentes	FoundryAsciiSmugglingInjection
Cadena multi-etapa (inyección → exfil)	Agentes	FoundryMultiStageAttackChain

El agente es una identidad con manos. Gobernarlo no es opcional, y el modelo de licencia acaba de cambiar.

1 jul 2026

La postura de seguridad de agentes Foundry y de terceros pasa a requerir licencia Microsoft Agent 365. Defender CSPM sigue descubriendo cuentas y proyectos, pero lo agent-level se mueve a Agent 365.

Agent 365 ya es GA (1-may-2026) · plan premium ~\$15/usuario/mes o incluido en Microsoft 365 E7.

Qué hacer ahora

- Inventariar agentes hoy con Defender for Cloud
- Presupuestar Agent 365 en el roadmap de licenciamiento
- No descubrir el cambio en producción

■ Para correr IA en producción con confianza

Confianza no es fe: es postura + detección en las cuatro capas.

1

Empieza por el AI BOM

Activa AI-SPM y genera tu inventario antes de discutir controles. No puedes proteger lo invisible.

2

Cada capa es superficie de ataque

Infra, datos, servicios, agentes: cada control colgado de un riesgo concreto, priorizado con attack path.

3

Planifica los agentes hoy

La seguridad de agentes se mueve a Microsoft Agent 365 el 1-jul-2026. Inclúyelo en tu roadmap, no en producción.

No estás asegurando un modelo.

Estás asegurando una cadena de suministro de IA, del código a la nube al agente. Y acaban de verla funcionando.

Gracias, por su atención!

